Project Phase 4: Fortifying the Network - Advanced Security

Due Date: End of Week 6 **Points:** 100

Scenario

The Riverside Cafe's architecture is now more resilient, but a security audit reveals a major vulnerability: the application server is still in a public subnet, making it a direct target for attacks. A more secure, industry-standard architecture is required.

Your task is to design and implement a new, highly secure Virtual Private Cloud (VPC) environment from scratch.

Project Goals

1. **Design** a **secure** multi-tier VPC with appropriate public and private subnets to isolate resources.
2. **Implement** a **Secure Remote Access** solution, such as creating a bastion host (jump box) in the public subnet as the only entry point for SSH access to private instances.
3. **Enable Secure Outbound Traffic** by implementing a NAT Gateway to allow private instances to access the internet for patches without being exposed to inbound traffic.
4. **Apply Layered Security** using both security groups and network ACLs to create a defense-in-depth security posture.

Technical Requirements

- You must create a new VPC. Do not use the default VPC.
- Your application server (from Phase 2) must be launched in the private subnet.
- Your database (from Phase 3) should also be hypothetically placed in a private subnet in this new VPC.

Submission Instructions

You will submit a single PDF document to Moodle. This document must contain all parts of the deliverable outlined below.

Deliverable Breakdown

- **The Network Architecture:** Provide a detailed **Architecture Diagram** of your new VPC. It must clearly show your VPC/CIDR, public/private subnets, Internet Gateway, NAT Gateway, route tables, the Bastion Host, and the Application Server in their correct locations. For each of the following components, explain its function within your architecture: Internet Gateway, NAT Gateway, and Bastion Host.
- **The Security Groups:** Detail and justify the inbound/outbound rules for the security group attached to your **Bastion Host**. Detail and justify the inbound/outbound rules for the security

group attached to your **Application Server**, explaining how it only accepts SSH traffic from the bastion host.

- **Network ACL Design:** What is the key difference between a security group and a network ACL? Design and detail the rules for a custom network ACL for your private subnet. Explain how these rules provide an additional layer of security. Describe the exact, multi-step process an administrator would follow to connect from their computer to the private application server. Explain why this is more secure than direct access.

Grading Rubric

Criteria	Description	Points
Network Diagram	Diagram is detailed, accurate, and includes all required components in their correct places.	30
Component Justification	Explanations for IGW, NAT GW, and Bastion Host are clear and correct.	20
Security Group Design	Security group rules are well-designed for least-privilege access and are clearly justified.	20
Network ACL Design	Demonstrates understanding of NACLs vs. Security Groups. NACL rules are logical and add a meaningful security layer.	20
Professionalism & Clarity	The submitted document is well-organized and clear. It also clearly discusses the team's working communication and individual contributions for the phase.	10
Total		**100**